

SECCIÓN 2.3



Amenazas, vulnerabilidades, riesgo e impacto

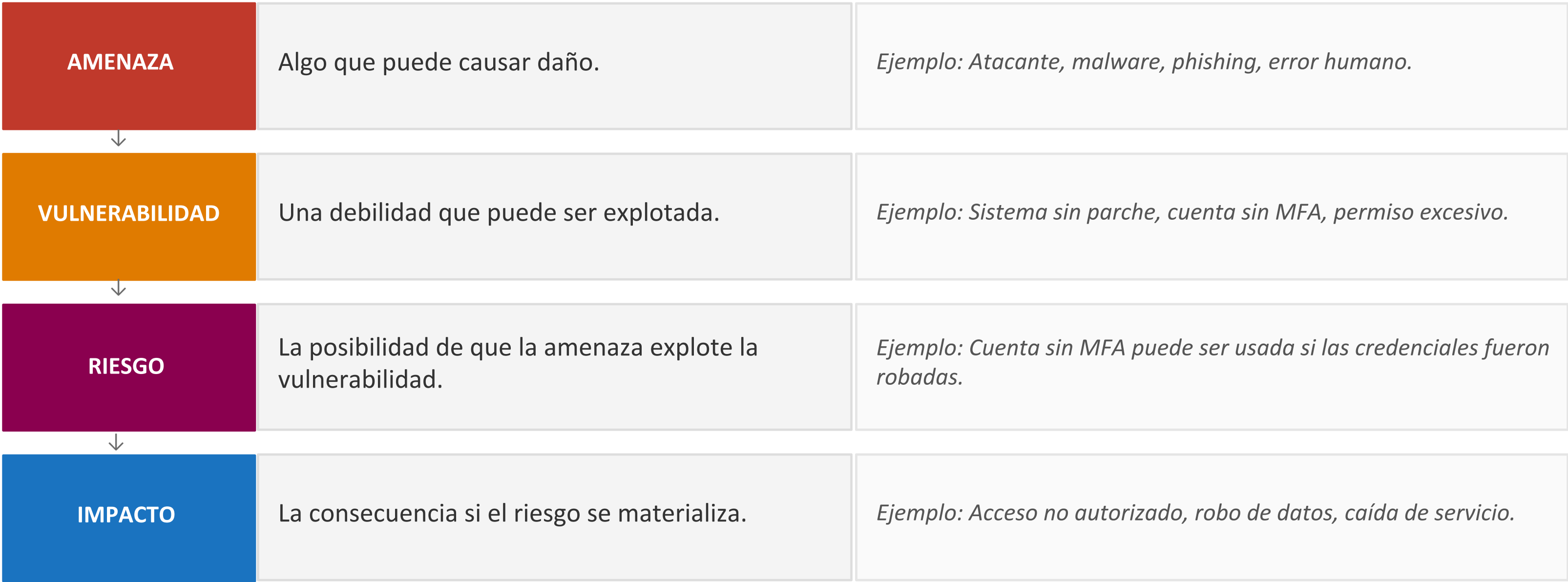
Temas de esta sección:

- Qué es una amenaza y por qué no es lo mismo que incidente
- Qué es una vulnerabilidad y cuándo implica riesgo
- Qué es riesgo: amenaza + vulnerabilidad + contexto
- Qué es impacto: potencial vs confirmado
- Cómo se conectan estos conceptos en un SOC
- Ejemplos: phishing, servidor vulnerable, malware bloqueado
- Errores comunes al usar estos términos

2.3 | La idea central: cuatro conceptos conectados pero distintos



Uno de los errores más comunes en SOC es usar estos conceptos como si fueran lo mismo. Cada uno representa una situación diferente:



2.3 | Amenaza: no significa incidente confirmado



El SIEM detecta múltiples intentos fallidos de login desde una IP externa. Eso puede representar una amenaza, pero no significa automáticamente que la cuenta esté comprometida.

El analista debería validar:

Cuántos intentos hubo y en qué período

Contra qué usuario o usuarios

Si hubo login exitoso posterior

Si el usuario tiene privilegios elevados

Si la IP tiene reputación sospechosa

Si hay otros eventos relacionados

La amenaza es una posibilidad de daño. El incidente requiere evidencia más fuerte de afectación o compromiso. Que exista una amenaza no significa que ya ocurrió un incidente.

2.3 | Vulnerabilidad: no significa explotación



Una vulnerabilidad es una debilidad que puede ser explotada. Su existencia aumenta el riesgo, pero no confirma compromiso.

Ejemplo: hallazgo de gestión de vulnerabilidades

Asset:	WEB-SRV-01
Severity:	Critical
Exploit observed:	No

Finding:	Apache vulnerable version detected
Exposure:	Internal only
Sensitive data:	No confirmed

El analista debería preguntarse:

- ¿El servidor está expuesto a internet?
- ¿Hay intentos de explotación en logs?

- ¿La vulnerabilidad tiene exploit activo conocido?
- ¿Existen controles compensatorios?

2.3 | Riesgo en contexto: el mismo hallazgo, distinto riesgo



Riesgo = Amenaza + Vulnerabilidad + Impacto potencial. No es una fórmula exacta, pero ayuda a razonar. El contexto determina si el riesgo es alto o bajo.

Finding: Servicio RDP habilitado — Puerto 3389

CASO 1	RDP solo en red interna, jump box, MFA, monitoreo, cuentas autorizadas. Requiere seguimiento pero no acción inmediata.	Riesgo: CONTROLADO
CASO 2	RDP expuesto a internet, sin MFA, múltiples intentos fallidos desde distintos países. Requiere acción urgente.	Riesgo: ALTO
CASO 3	RDP expuesto, login exitoso desde IP desconocida, ejecución de comandos posterior. Escalar inmediatamente.	Riesgo: MUY ALTO (posible incidente en curso)

El puerto es el mismo. El riesgo cambia por exposición, controles, comportamiento y evidencia.

2.3 | Ejemplos aplicados: phishing, servidor vulnerable, malware bloqueado



Tres escenarios frecuentes en SOC, analizados con los cuatro conceptos:

PHISHING	SERVIDOR VULNERABLE	MALWARE BLOQUEADO
 Amenaza Campaña de phishing. Vulnerabilidad Usuario expuesto, posible falta de controles. Riesgo Compromiso de credenciales.  Impacto Potencial: acceso no autorizado a la cuenta.	 Amenaza Actor externo intentando explotación. Vulnerabilidad Aplicación con falla explotable. Riesgo Acceso no autorizado a archivos.  Impacto Por ahora no confirmado — WAF bloqueó el request.	 Amenaza Archivo potencialmente malicioso. Vulnerabilidad Usuario descargó archivo sospechoso. Riesgo Ejecución de malware en endpoint.  Impacto No confirmado — ejecución bloqueada por EDR.
Validar: Validar si ingresó credenciales · MFA posterior · Reglas de reenvío · Acceso a info sensible	Validar: ¿Hubo requests permitidos? · ¿Respuestas anómalas? · ¿Archivos modificados? · ¿Actividad posterior?	Validar: Origen del archivo · ¿Otros usuarios? · ¿Ejecución parcial? · ¿Correo asociado? · ¿Hash en otros hosts?

2.3 | Errores comunes al interpretar riesgo



Errores frecuentes que afectan la calidad del análisis:

✗ Usar los términos como sinónimos

✓ 'Tenemos un riesgo crítico porque hay una IP maliciosa.' — Una IP maliciosa es un indicador, no un riesgo confirmado sin contexto.

✗ Confundir vulnerabilidad con incidente

✓ Un hallazgo crítico no significa compromiso. La explotación requiere evidencia de actividad maliciosa.

✗ Ignorar una amenaza porque fue bloqueada

✓ El EDR bloqueó un archivo, pero ¿cómo llegó? ¿Llegó a otros usuarios? ¿Hubo ejecución parcial?

✗ No documentar impacto potencial vs confirmado

✓ 'Puede haber exfiltración' es diferente a 'se confirmó exfiltración'. El lenguaje importa.

✗ Priorizar solo por severidad automática

✓ Una alerta media en cuenta admin puede ser más urgente que una alta en laboratorio.